PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Pilotage et remédiation cyber

03-930 ANSSI - Cyberattaques et remédiation, clés de décision, pilotage, Tier 0 Active Directory et préparation — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La séquence E3R articule l'endiguement, l'éviction, l'éradication et la reconstruction pour reprendre le contrôle.
2. Le modèle d'administration en tiers sépare le Tier 0 (contrôle des identités), le Tier 1 (valeurs métier) et le Tier 2 (postes de travail).
3. La remédiation transforme l'incident en opportunité de résilience en modifiant le cycle de vie du SI sur plusieurs semaines ou mois.

La collection Cyberattaques et remédiation

Notion	À retenir
Corpus à trois niveaux	**4 documents** en 3 volets : **stratégique** (décideurs), **opérationnel** (RSSI, DSI, pilotage), **technique** (**Tier 0 Active Directory**). Réponse à incident : **remédiation**, **investigation**, **gestion de crise**.
Projet long	Modifie le cycle de vie du SI pendant **plusieurs semaines voire plusieurs mois** ; transforme l'incident en opportunité de **résilience** face à une **intelligence hostile**.

La séquence E3R et le cœur de confiance

Notion	À retenir
Les étapes	**Endiguement** : stoppe la progression, donne du temps. **Éviction** : chasse l'intrus du cœur pour recréer une base de confiance. **Éradication** : élimine les capacités de retour (portes dérobées). **Reconstruction** : en parallèle.
Cœur de confiance	Brique d'où l'attaquant est **exclu de façon certaine** ; échec de sa reconstruction = cycles de compromission sur des mois ou années ; simple nettoyage médiocre ; tout import contrôlé depuis le nouveau cœur.

Synthèse des clés de décision

Notion	À retenir
Scénarios types	1 : **services vitaux** (péril immédiat), 2 : **reprendre le contrôle** (état antérieur), 3 : **maîtrise durable** (modèle proactif).
Les coûts	1 : **coût total très élevé** (résurgence), 2 : **étalement** (impact métiers), 3 : **rentable à terme**. Dégâts : **millions** ou **dizaines de millions d'euros**.
Recommandations	**Piloter** (long terme), **choix structurants**, **objectifs métiers**, **réactivité**, **flexibilité**, **facteur humain**, **horizon viable**.

Pilotage de la remédiation

Notion	À retenir
Les étapes du pilotage	Décliner les **objectifs stratégiques** en **opérationnels**, mobiliser les **moyens**, identifier les **porteurs**, lancer les **sous-projets** et **communiquer** l'avancement.
Rôle des métiers	Orientent la remédiation (impacts, priorités, validation avant reprise) ; objectifs mesurés à la **capacité des métiers à travailler** ; menace vitale = **crise**.
Gérer la durée	Un **marathon** : tenir le plan dans la durée compte plus que le rythme ; check-lists par scénario.

Remédiation du Tier 0 Active Directory

Notion	À retenir
Modèle trois tiers	Modèle en tiers (Microsoft) : **Tier 0** identités, **Tier 1** valeurs métier (serveurs, applications, comptes de service), **Tier 2** postes ; comptes admin séparés, **postes dédiés** ; **RID 500** réservé aux urgences (bris de glace).
Actions d'éviction	Réinstaller les machines Tier 0 si la **compromission ne peut être exclue**. Supprimer chemins dangereux, délégations et permissions **adminSDHolder**. Renouveler les secrets (**krbtgt** changé **2 fois**, sinon une base extraite reste exploitable).
Administration sécurisée	Structure d'**OU** protégeant le Tier 0, comptes et postes dédiés. Politique de **mots de passe robuste**, réduction des comptes privilégiés et **supervision** du Tier 0.

Préparer la remédiation

Notion	À retenir
Le constat	Les plans de **continuité** et de **reprise d'activité** sont rarement adaptés aux évènements de cybersécurité d'ampleur.
Les points à préparer	Préparer les **plans** (continuité, reprise, restauration, kits), la **communication** (discrétion), la **connaissance du système** (cartographies, accès), la **coordination**, les **parties prenantes**, les **accès** (bris de glace), les **indispensables techniques** et la **dimension humaine**.

Pièges et confusions

⚠ Croire qu'il suffit de nettoyer l'ancien cœur de confiance : il faut le reconstruire et contrôler tout élément importé.
⚠ Croire que le scénario 1 est le plus rentable sur la durée alors qu'il est le plus coûteux à long terme.
⚠ Oublier que l'échec de la reconstruction du cœur de confiance entraîne des cycles de compromission répétés.
⚠ Négliger la discrétion car l'attaquant peut observer les échanges des défenseurs.
⚠ Ne changer le mot de passe du compte krbtgt qu'une seule fois au lieu de deux fois.

Sigles et définitions

Remédiation	Projet de reprise de contrôle d'un système d'information compromis et de rétablissement d'un état de fonctionnement suffisant.
Cœur de confiance	Partie du système dont la compromission ferait suspecter la compromission de tout le système.
Tier 0	Niveau rouge contenant les ressources ayant le contrôle des identités de l'entreprise.
Chemin de contrôle	Enchaînement de droits permettant à un compte ou une machine de prendre le contrôle d'un objet sensible de l'annuaire.
Compte krbtgt	Compte qui stocke les clés des centres de distribution Kerberos.
Compte bris de glace	Compte aux droits étendus, conservé hors ligne, destiné aux incidents graves.

Auto-test

1. Quelles sont les trois dimensions de la réponse à incident cyber ?
2. Combien de fois le mot de passe du compte krbtgt doit-il être changé ?
3. Que contient le Tier 1 dans le modèle d'administration en niveaux ?
4. Quel est l'objectif de l'endiguement ?
5. À quoi se mesurent les objectifs de la remédiation ?

Réponses : **1.** La remédiation, l'investigation et la gestion de crise. · **2.** 2 fois. · **3.** Les ressources contrôlant les valeurs métier (serveurs, applications, comptes de service). · **4.** Stopper la progression de l'attaquant et donner du temps au défenseur. · **5.** À la capacité des métiers à travailler.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.